Ejercicio 4: Aplicación web de imágenes

Junior Cueva Fabian · 14 de octubre de 2026

Arquitectura y seguridad

El navegador solicita enlaces temporales a la API. Envía la imagen directamente a un bucket S3 privado mediante PUT. La API comprueba tipo, tamaño y firma inicial del archivo después de la carga. Los enlaces de subida duran 5 minutos y los de lectura 15 minutos. No hay claves AWS en el frontend.

Pruebas realizadas

Comprobación	Resultado
CORS del bucket	Preflight OPTIONS: 200; origen local permitido.
Carga JPG desde navegador	PUT directo a S3; imagen visible en la galería.
Archivo PDF	Bloqueado en el navegador.
Archivo de 10 MB	Rechazado por la API con HTTP 400.
Subidas masivas	Solicitud 11 en un minuto: HTTP 429.
Archivo con tipo falso	La firma real no coincide: carga rechazada.
Caducidad de URL	Enlace de 15 min: HTTP 200 al inicio y 403 tras 16 min.
Credenciales en frontend	Sin Access Keys ni secretos en los archivos públicos.

Preguntas de análisis

1. ¿Por qué presigned URLs?

Permiten acceso solo a una operación y un objeto durante un tiempo corto. El bucket permanece privado.

2. ¿Y si se intercepta la URL?

Puede usarse hasta su vencimiento. Se reduce el riesgo con HTTPS, permisos mínimos y caducidad corta.

3. ¿Cómo quitar claves en EC2?

Asignar un IAM Role de mínimo privilegio a la instancia. El SDK obtiene credenciales temporales; no se guardan claves en .env.

4. ¿Cómo evitar subidas masivas?

Aplicar límite por usuario o IP y cuotas. La API limita a 10 solicitudes de URL por minuto e IP.

5. ¿Qué otras validaciones?

Verificar magic bytes, decodificar la imagen y pasar un antivirus antes de publicarla.

Código y referencias

Repositorio: github.com/juniorcueva-star/SEMANA_9_NUBE_PAGINA_WEB
Fuentes: documentación de Amazon S3 Presigned URLs; IAM Roles para EC2; OWASP File Upload y Denial of Service Cheat Sheets.